香港浸會大學
HONG KONG BAPTIST UNIVERSITY

COMP4127/COMP7850

Information Security

Wireless LAN Security

Reference: Sections 13.1-13.6, 27.3
William Stallings, “Data and Computer Communications”, 10th Edition.

Learning outcomes

After this lecture, you should be able to:

- Describe the architecture of modern wireless networks.
- Name the key phrases of 802.11i.
- Identify some weaknesses of the WEP protocol.

Outline

- Background about Wireless LAN
- Security of Wireless LAN

Wireless LAN

Wireless LAN is designed as a wireless version of the traditional wired LAN

- local area network: covering a limited area such as apartment, office, or campus
- wireless: relying on the wireless communication techniques

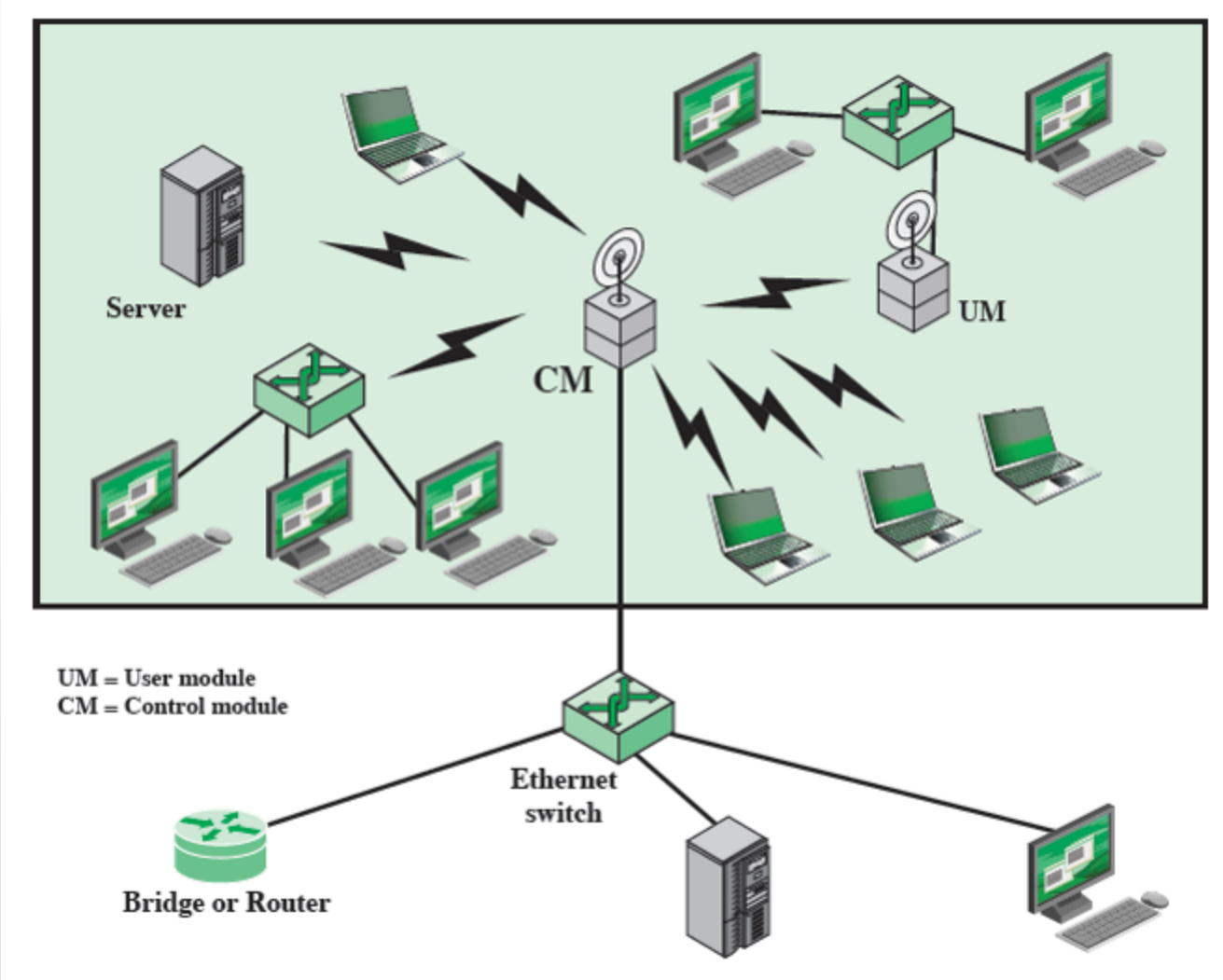
Today, most wireless LANs are based on IEEE 802.11 standards and marketed as WiFi

Wireless LANs are usually connected to a wired backbone.

Wireless LAN configuration 結构

Infrastructure Mode, Single-cell WLAN 基础设施

- All wireless end systems (called **user module** UM) are within range of a single **control module** (CM).
- E.g., a typical home WiFi network

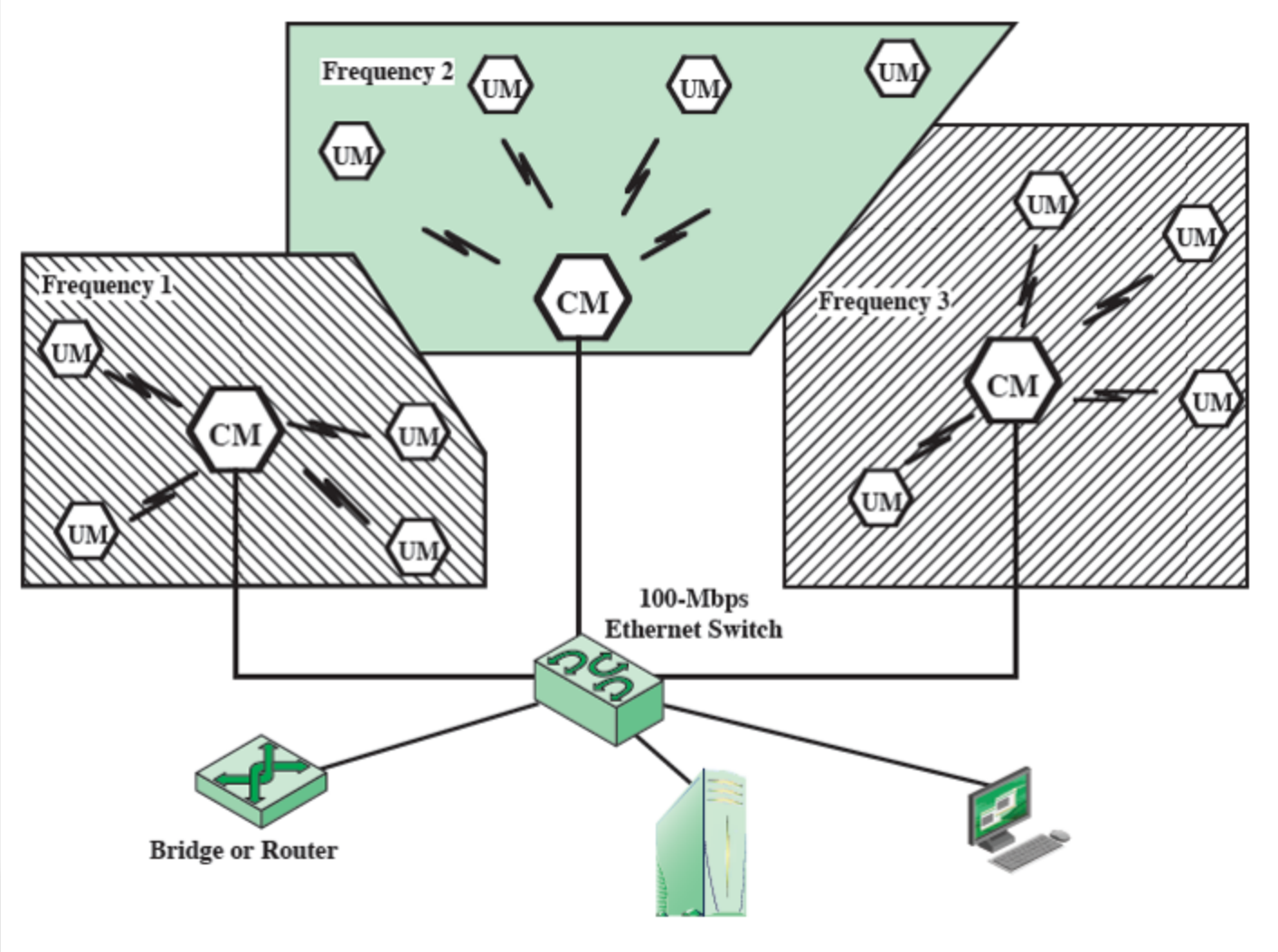


Wireless LAN configuration

Infrastructure Mode, Multiple-cell WLAN

- Multiple CMs are interconnected by a network to cover a larger area
- E.g., HKBU campus WiFi network, or the HK Airport WiFi network

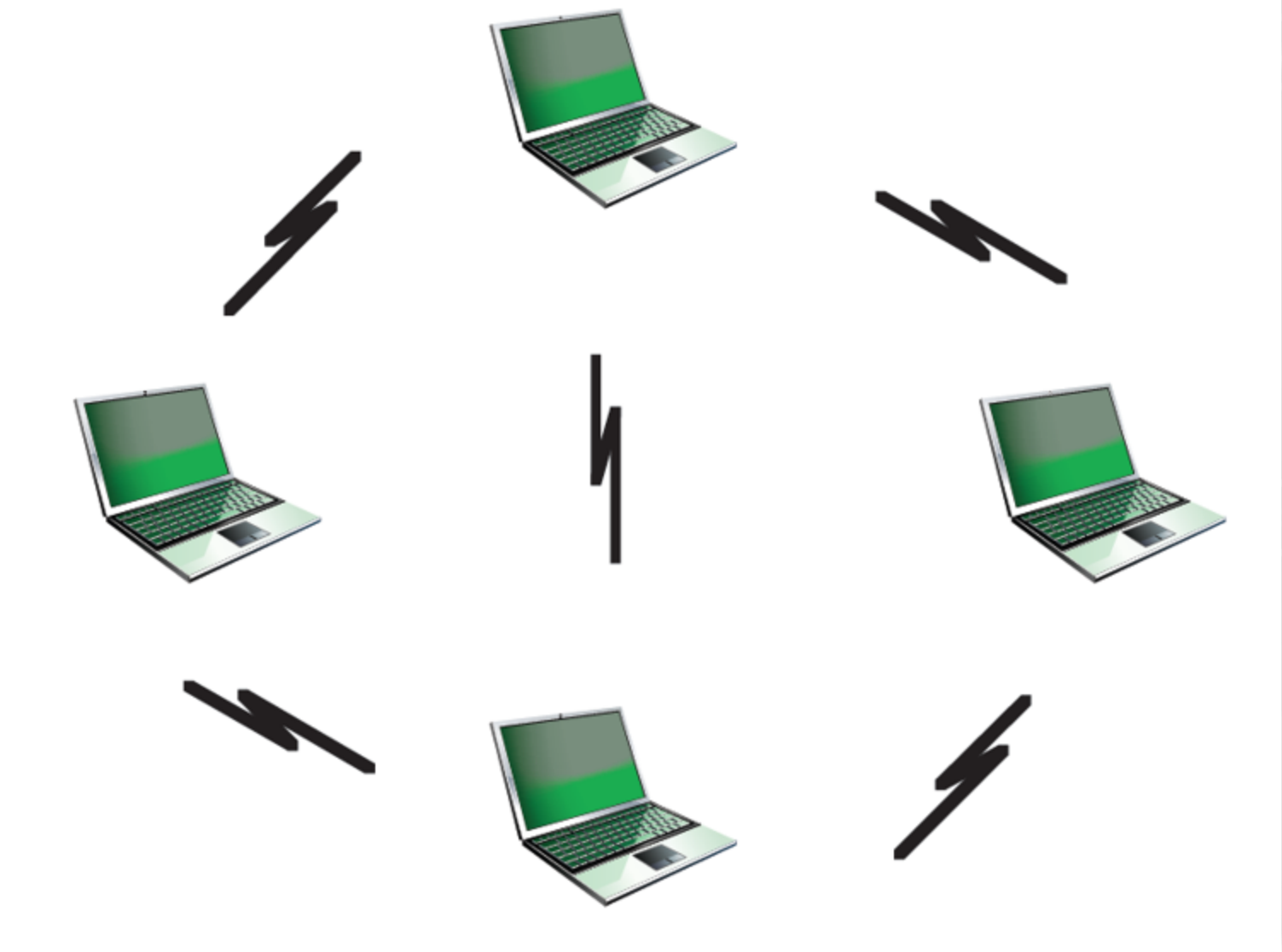
Adjacent cells use different frequencies to avoid interference.



Wireless LAN configuration

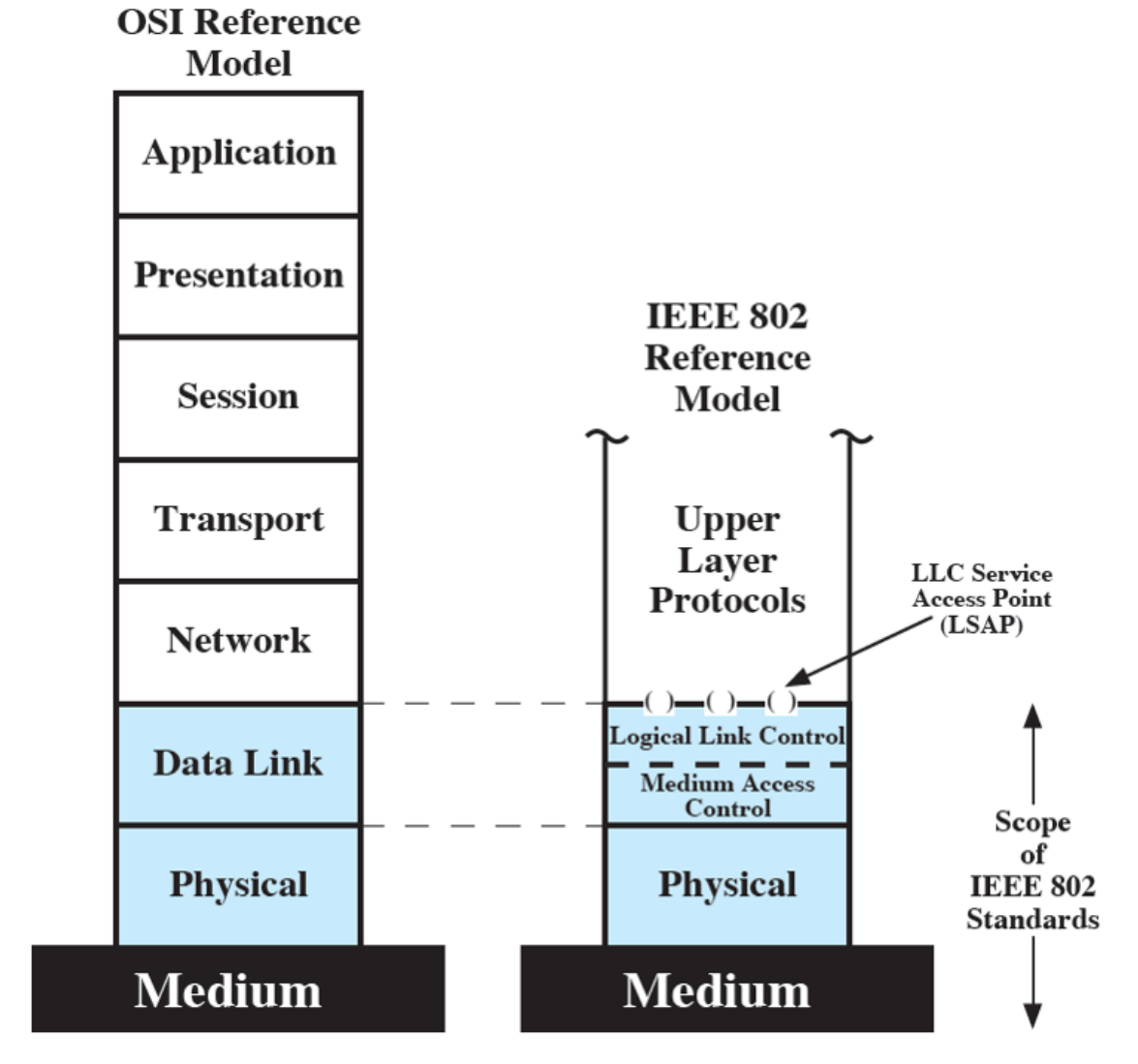
Ad Hoc WLAN

- without control module (CM)
- UM communicate with their neighbors directly



IEEE 802 Architecture

Physical Layer (PHY): The lowest layer of the IEEE 802 reference model is the physical layer, which includes such functions as encoding/decoding of signals and bit transmission/reception.
Media Access Control (MAC): Some means of controlling access to the transmission medium is needed to provide an orderly and efficient use of the network transmission capacity.
Logical Link Control (LLC): Keeps track of which frames have been successfully received and retransmits unsuccessful frames.



IEEE 802.11 Standards

IEEE 802.11 is an open standard.

- Different products may implement the standard differently.
- There is a concern whether products from different vendors will successfully interoperate. 小版

The Wi-Fi (Wireless Fidelity) Alliance 結盟,

- Created a test suite to certify interoperability for 802.11 products

Standard	Scope
IEEE 802.11a	Physical layer: 5-GHz OFDM at rates from 6 to 54 Mbps
IEEE 802.11b	Physical layer: 2.4-GHz DSSS at 5.5 and 11 Mbps
IEEE 802.11c	Bridge operation at 802.11 MAC layer
IEEE 802.11d	Physical layer: Extend operation of 802.11 WLANs to new regulatory domains (countries)
IEEE 802.11e	MAC: Enhance to improve quality of service and enhance security mechanisms
IEEE 802.11g	Physical layer: Extend 802.11b to data rates >20 Mbps
IEEE 802.11i	MAC: Enhance security and authentication mechanisms
IEEE 802.11n	Physical/MAC: Enhancements to enable higher throughput
IEEE 802.11T	Recommended practice for the evaluation of 802.11 wireless performance
IEEE 802.11ac	Physical/MAC: Enhancements to support 0.5-1 Gbps in 5-GHz band
IEEE 802.11ad	Physical/MAC: Enhancements to support ≥ 1 Gbps in the 60-GHz band

Key IEEE 802.11 Terminology

Terminology	Explanation
Access point (AP)	Any entity that has station functionality and provides access to the distribution system via the wireless medium for associated stations
Basic service set (BSS)	A set of stations controlled by a single coordination function
Distribution system (DS)	A system used to interconnect a set of BSSs and integrated LANs to create an ESS
Extended service set (ESS)	A set of one or more interconnected BSSs and integrated LANs that appear as a single BSS to the LLC layer at any station associated with one of these BSSs
Frame	Synonym for MAC protocol data unit
Station (STA)	Any device that contains an IEEE 802.11 conformant MAC and physical layer

IEEE 802.11 Architecture

Basic Service Set (BSS)

Stationd BSS

BSS is the smallest building block of a WLAN. It consists of some stations running the same MAC protocol and competing for access to the same shared wireless medium

Extended Service Set (ESS)

Multiple BSSs can be interconnected by a Distribution System (DS). An ESS appears as a single logical LAN to the logical link control level.

- **SSID**: Service Set Identifier, e.g., “BU-Standard”

Each BSS connects to DS through an Access Point (AP), which functions as a bridge and a relay point. In general, all communications within an BSS or between the BSS and DS should go through the AP

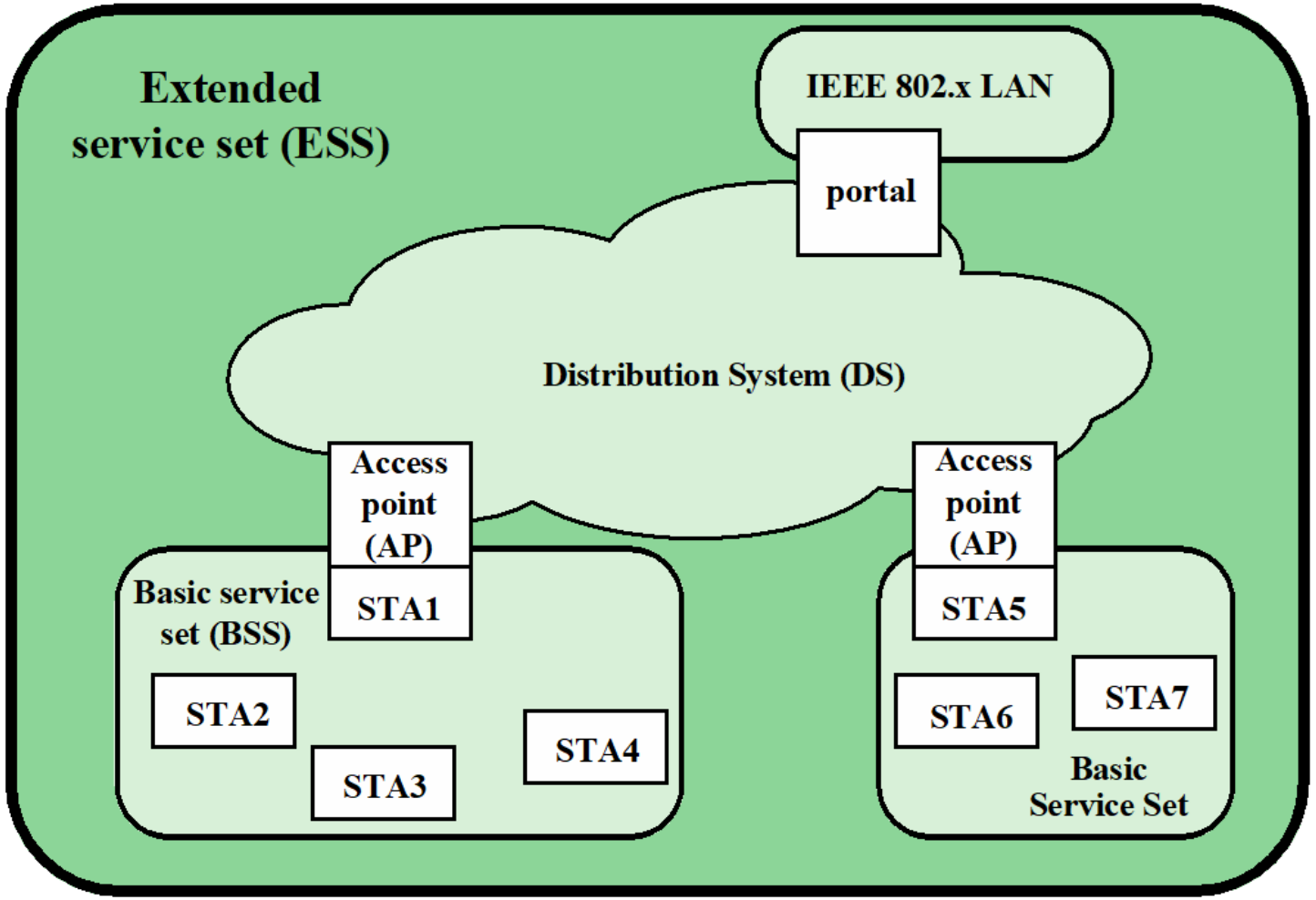
Independent BSS (IBSS)

IBSS is typically ad hoc WLAN. Stations communicate directly in an IBSS.

IEEE 802.11 Architecture

Roaming

无线漫游



STA = station

Figure 13.4 IEEE 802.11 Architecture

802.11 Medium Access Control

Data link layer

The IEEE 802.11 MAC layer covers three functional areas: reliable data delivery, access control, and security.

- **Reliable Data Delivery**: wireless channels are usually unreliable. Mechanism is developed for error detection and contention.
- **Access control**: stations are competing for the wireless transmission. Mechanism is developed for deciding which station can send.
- **Security**: to make sure the confidentiality and data integrity. Disallowing unauthorized station to connect to the network.

ISM Band 2.4GHz/5GHz for 802.11

Industrial, Scientific and Medical (ISM) radio bands are reserved internationally for industrial, scientific and medical purposes other than telecommunications in different countries.

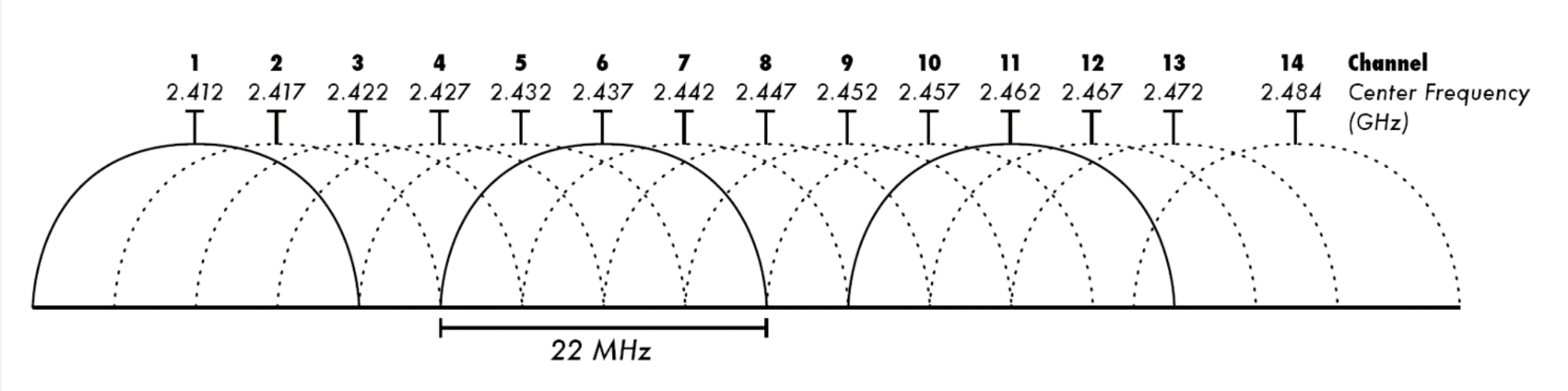
电信等.

2.4GHz defines 100 MHz bandwidth (2.4-2.5 GHz), divided into 14 overlapping channels with 22 MHz of bandwidth.

部分重叠

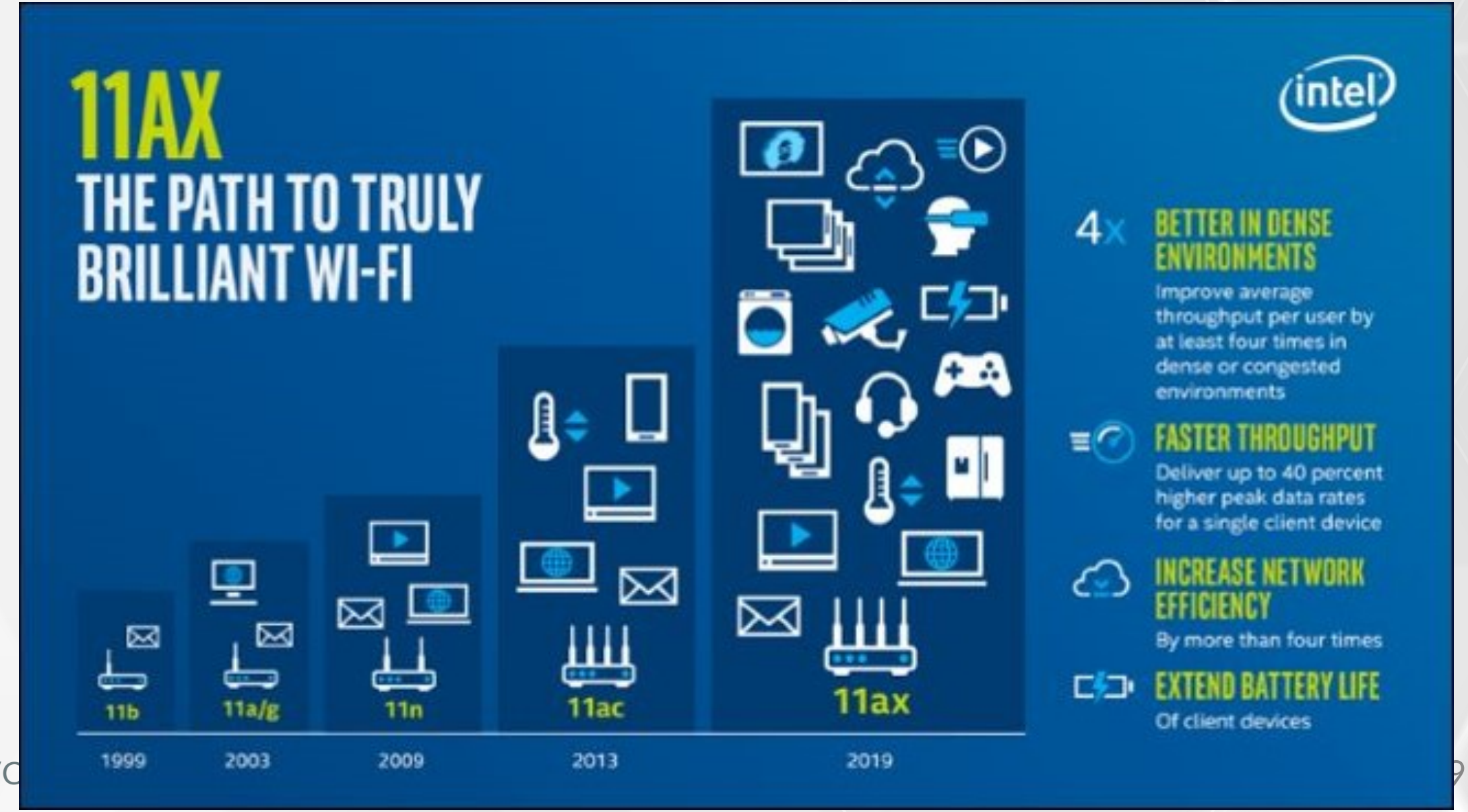
5GHz defines 150 MHz bandwidth covering 5 channels.

?



3 bands to achieve interface

IEEE 802.11


11AX
THE PATH TO TRULY BRILLIANT WI-FI
intel
11b
11a/g
11n
11ac
11ax
1999
2003
2009
2013
2019
4x
BETTER IN DENSE ENVIRONMENTS
Improve average throughput per user by at least four times in dense or congested environments
FASTER THROUGHPUT
Deliver up to 40 percent higher peak data rates for a single client device
INCREASE NETWORK EFFICIENCY
By more than four times
EXTEND BATTERY LIFE
Of client devices

IEEE 802.11

Wi-Fi generations V·T·E

Generation	IEEE standard	Adopted	Maximum link rate (Mbit/s)	Radio frequency (GHz)
Wi-Fi 8[1]	802.11bn	2028	100,000[2]	2.4, 5, 6, mmWave
Wi-Fi 7	802.11be	2024	1376–46,120	2.4, 5, 6
Wi-Fi 6E	802.11ax	2020	574–9608[3]	6[a]
Wi-Fi 6		2019		2.4, 5
Wi-Fi 5	802.11ac	2014	433–6933	5[b]
Wi-Fi 4	802.11n	2008	72–600	2.4, 5
*(Wi-Fi 3)**	802.11g	2003	6–54	2.4
*(Wi-Fi 2)**	802.11a	1999		5
*(Wi-Fi 1)**	802.11b	1999	1–11	2.4
*(Wi-Fi 0)**	802.11	1997	1–2	2.4

**Wi-Fi 0, 1, 2, and 3 are named by retroactive inference. They do not exist in the official nomenclature.[4][5][6]

https://en.wikipedia.org/wiki/IEEE_802.11be

Threads in Wireless LANs

香港浸會大學 HONG KONG BAPTIST UNIVERSITY

Eavesdropping 偷听

- Due to the broadcast nature of radio communications
- The wireless signals can be received by any receiver within some transmission range

No physical protection

- The access to a wired LAN is protected by the physical cables
- A wireless LAN is open to an area surrounding the access point

WEP

Wired Equivalent Privacy (WEP) was adopted in IEEE 802.11 standard since 1997. It is designed to provide some security features:

Authentication

Only authorized users are allowed to access the WiFi network.

Data confidentiality:

The transmitted data are encrypted by a secret key.

WEP: Authentication

- Objective: the WiFi network can only be used by legal users
- How to define "legal users"?
  - A "secret key" is shared by legal users and the AP

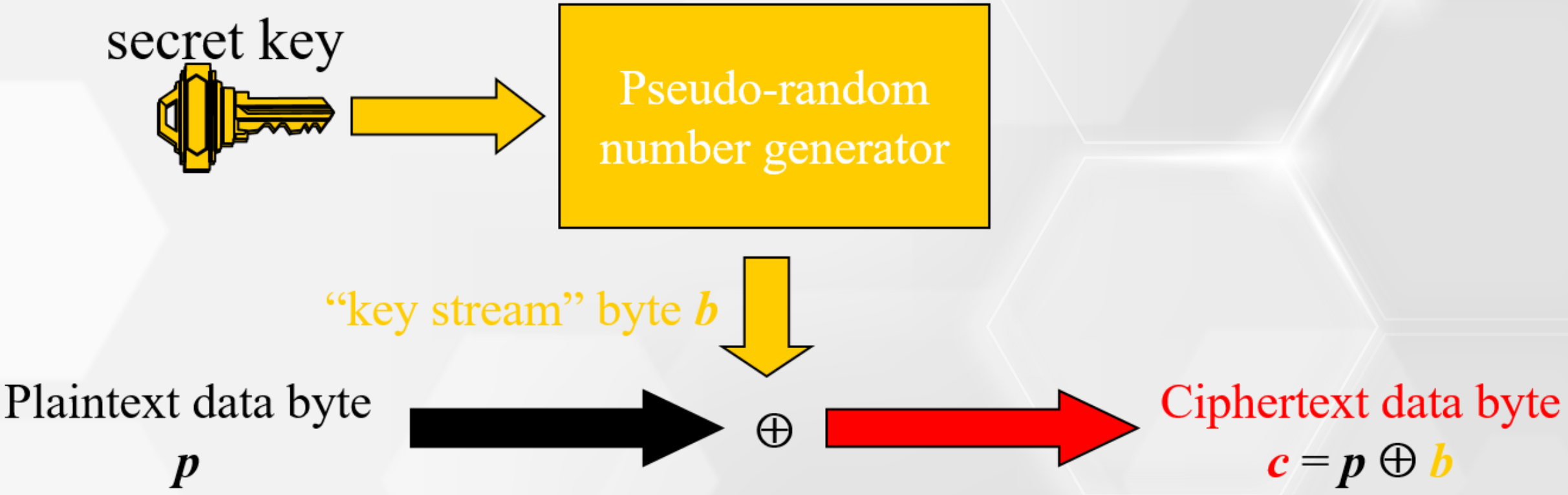
? How to know for the 1st time

How to authenticate?

1. A client submits an authentication request to AP.
2. The AP generates a random challenge and sends it to the client.
3. The client encrypts the challenge by the secret key and sends the result to AP.
4. The AP decrypts the message and compares with the challenge. If same, the user is considered legal; otherwise, the user is not allowed to join the WiFi network.

WEP: Data Encryption

For every WiFi packet, the sender applies RC4 stream cipher to encrypt the data. ?



💡 Is it secure?

access URL → got p also c

→ b calculated.

Problems with WEP

错误、弱点、缺

Many design flaws in WEP were found by researchers around year 2000.

Authentication flaws:

相互的

- The authentication in WEP is not mutual. The AP doesn't authenticate itself to the clients.
- Authentication and encryption use the same secret key.
- A client is authenticated only at the time when it tries to connect to the network. After authentication, anyone else can send message in the name of this authenticated user by spoofing its MAC address..

Problems with WEP

Integrity flaw:

- WEP uses CRC algorithm, which is linear with respect to XOR operations.
- The attack can manipulate protected WEP messages by flipping any of their bits unnoticeably.

Confidentiality flaw:

secert key → section key

- WEP uses RC4 cipher with a short IV with 24-bit long, so the pseudo-random sequences will repeat in a limited time.
- An attacker can crack the secret key by eavesdropping a few million messages.

使爆炸

破解

偷听.

WPA, WP2, WPA3

New security architecture 802.11i is designed to replace WEP during 2003-2004.

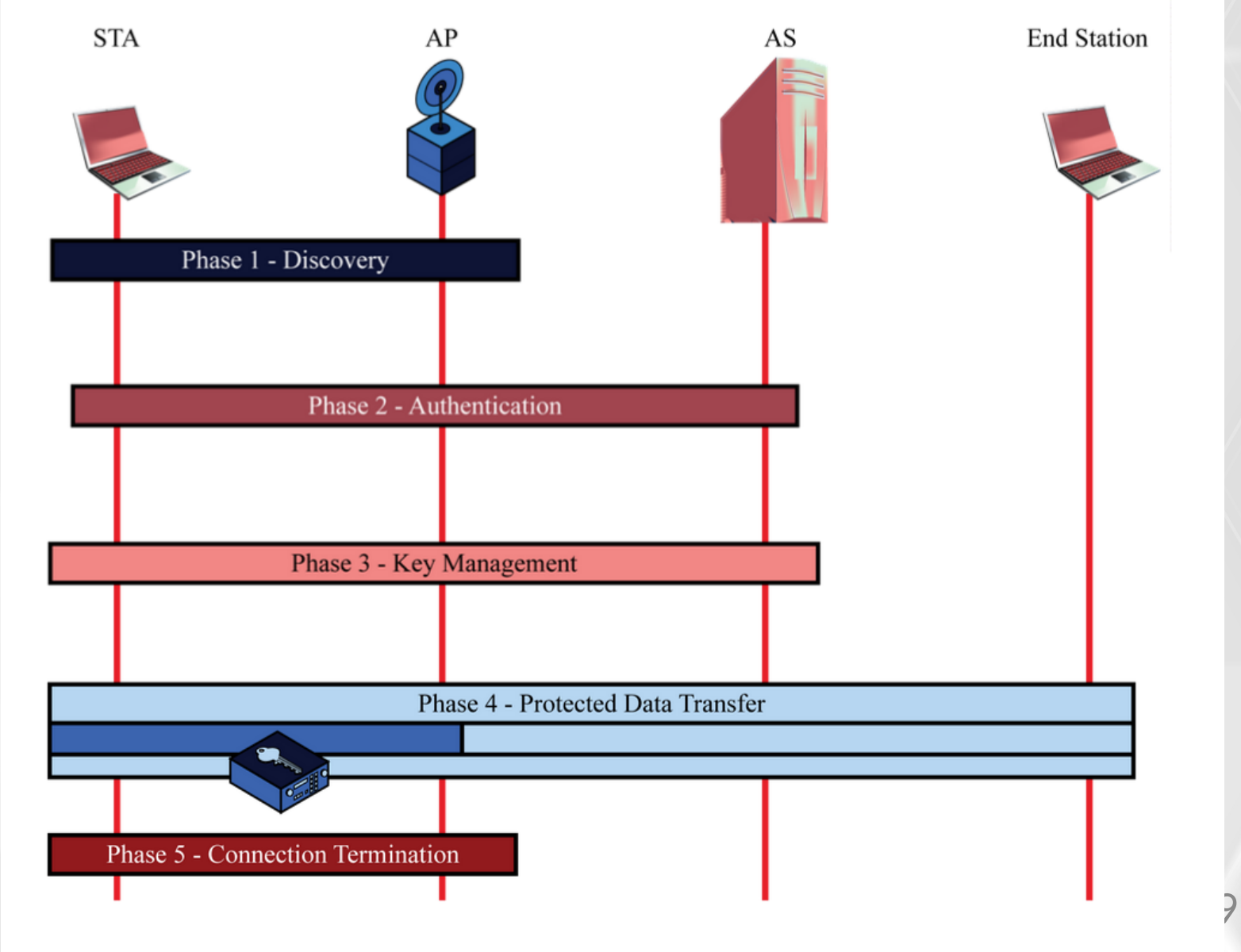
- WPA (WiFi Protected Access) is an intermediate solution which can be implemented by updating the firmware of existing APs. 固件.
- WPA2 (WiFi Protected Access II) is the long term solution. Now it is 强制的 mandatory for WiFi certification.
- WPA3 is the next generation of security scheme, all WiFi 6 certified routers are required to implement.
- After WiFi 6E, only WPA3 shall be supported.

802.11i Service

IEEE802.11i is a standard that includes WPA2 to replace WEP. It specifies security mechanisms for wireless networks.

Role:

- STA: Station
- AP: Access point
- AS: Authentication Server



Phase 1: Discovery

Discovery phase allows an STA and an AP to recognize each other, agree on a set of security capabilities, and establish an association for future communication.

- Network and security capability discovery: STAs discover the existence of a BSS. The AP periodically broadcasts its security through the Beacon frame, or it responds to a STA's Probe Request frame through a Probe Response frame.
- Open system authentication: STA and AP exchange identifiers.
- Association: STA sends an Association Request frame to AP, which specifies a set of matching security capabilities. AP replies an Association Response frame.

Phase 2: Authentication Phase

This phase enables mutual authentication between an STA and an AS.

- Only authorized STAs can use the network.
- STA is assured that the network is legitimate. 合法的

IEEE 802.11i relies on another standard, IEEE 802.1X for access control. The authentication protocol is called **Extensible Authentication Protocol** (EAP). Common EAP methods:

- EAP-TLS
- EAP-SIM
- EAP-AKA
- LEAP
- EAP-TTLS
- PEAP-MSCHAPv2

Extensible Authentication Protocol (EAP)

EAP defines three roles:

- Supplicant: the wireless STA
- Authenticator: the AP
- Authentication server (AS): a separate device or the AP

The authentication phase has three sub-phases:

- Connect to AS: the STA sends a request to its AP for connection to the AS. The AP forwards the request to the AS.
- EAP exchange: this exchange authenticates the STA and AS to each other.
- Secure key delivery: once authentication is established, the AS generates a **master session key** and sends it to STA, which enables future secure communications between STA and AP.

Note: A master session key is used to derive the encryption and integrity keys.

Phase 3: Key Management Phase

During this phase, a variety of cryptographic keys are generated and distributed to STAs.

- Pairwise keys used for communication between an STA and an AP.
- Group keys used for multicast communication.

Phase 4: Protected Data Transfer Phase

Symmteric?

- IEEE 802.11i defines two schemes for protecting data transmitted in 802.11 MPDUS:

暂存的

TKIP for WPA: Temporal Key Integrity Protocol

- It allows firmware update on older WiFi devices with WEP
- It introduces a new 64-bit Message Integrity Code to replace the CRC code in WEP.
- It still uses RC4 encryption algorithm. ?

AES-CCMP for WPA2: Counter Mode-CBC MAC Protocol

- Designed for new hardware
- It uses Cipher-Block-Chaining Message Authentication Code to provide data integrity.
- It uses AES algorithm for encryption.

Whenever it is possible, never use TKIP!

Recent Development

KRACK

Implementation fault about WPA2 in many devices.
https://www.krackattacks.com

Dragonblood

Design flaw in WPA3 that leaks key from side channel information
https://wpa3.mathyvanhoef.com